PRACTICAL LABORATORY ASSIGNMENT

Full Name	OSAWARU PRAISE
Registration Number	C11/26/CGRCE/17564
Date Submitted	25th October 2026
Course	GRC 103 Week 1
Linux Distribution Used	Kali Linux & Metasploitable

Phase 1: Discovery and Enumeration

1. Nmap output files (initial_scan.nmap, initial_scan.xml).

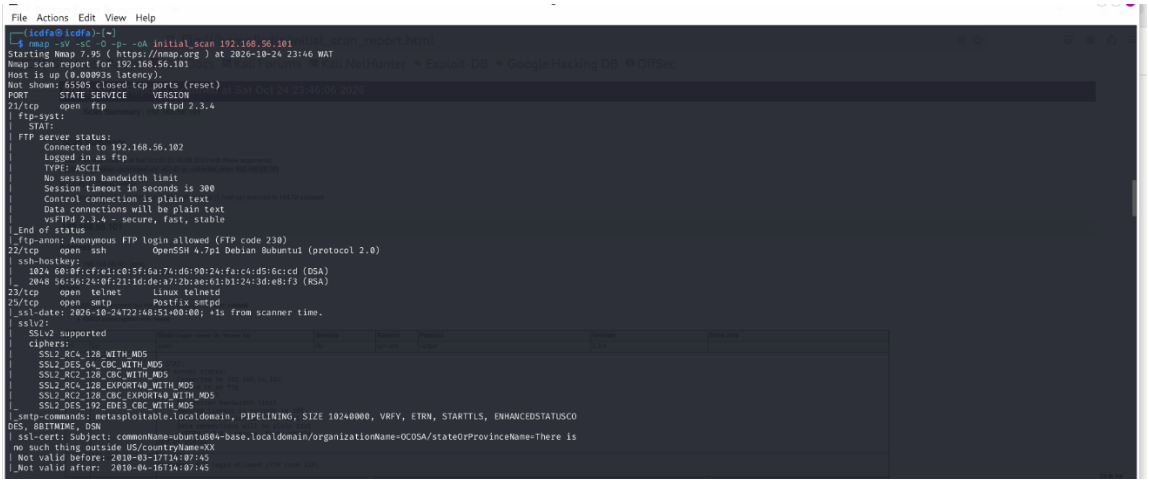


Figure 1Nmap output files

2. Screenshot of the Nmap HTML report (initial_scan_report.html).

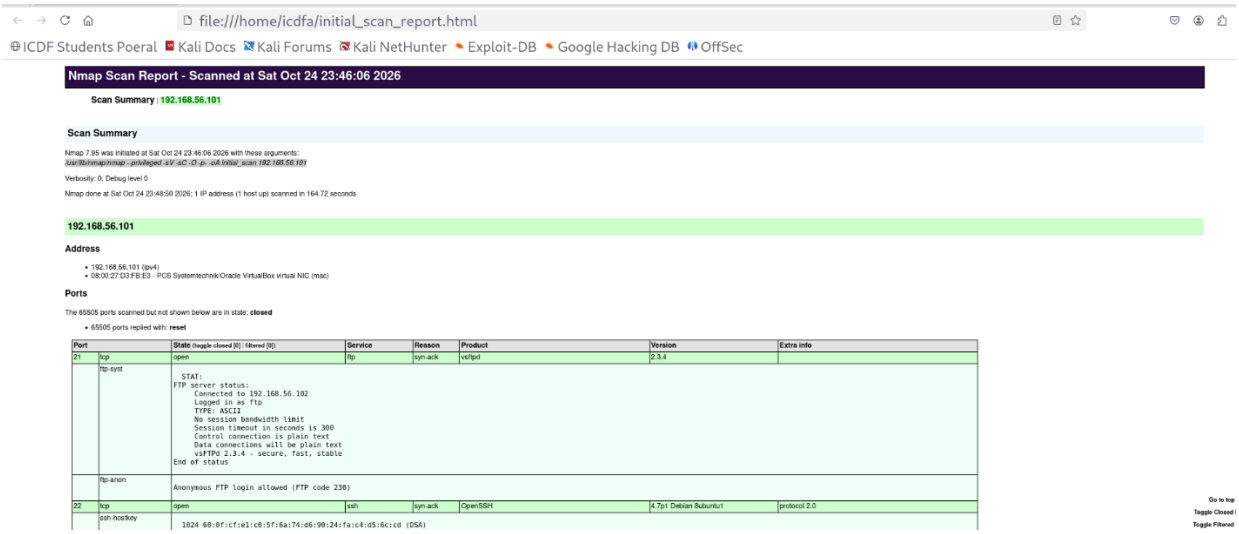


Figure 2 NMAP HTM Scan Report

GRC Question: Why is knowing which ports are open (e.g., 21/FTP, 23/Telnet) a compliance issue?

Answer: Every open port is attack surface; CIS Control 9 (Limitation of Network Ports) and NIST CSF PR.IP-1 both require minimizing unnecessary exposed services as part of secure baseline configuration. Unused services = unmanaged risk the org can't account for.

Phase 2: Vulnerability Identification

1. Nikto Scan Output

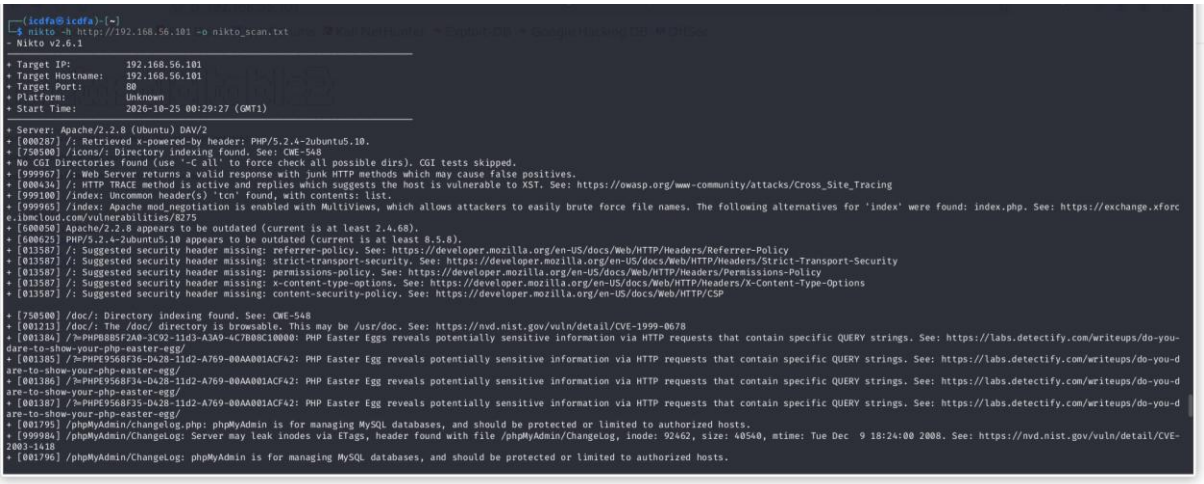


Figure 3 NiktonScan Output

2. Nuclei Scan Output



Figure 4 Nuclei Web Scan Output



Figure 5 Nuclei Full Scan Output

Phase 3: Analysis and Reporting (The Core GRC Task)

Finding	Affected Service	CVE/Reference	Inherent Risk (L/M/H)	Compliance Violation	Business Impact
vsftpd 2.3.4 backdoor (smiley face backdoor)	FTP – port 21/6200	CVE-2011-2523	H	PCI DSS 6.2 (patch management); CIS Control 7	Full remote root shell — complete system compromise with no authentication
Apache Tomcat Ghostcat AJP RCE	AJP Connector – port 8009	CVE-2020-1938	H	NIST CSF PR.IP-12 (vulnerability mgmt); PCI DSS 6.2	Remote attacker can read arbitrary files or achieve RCE on the web server
Samba legacy version	SMB – port 445	CVE-2026-4480	H	CIS Control 7; ISO 27001 A.12.6.1	Potential remote exploitation of file-sharing service; lateral movement risk
distcc remote code execution	distccd – port 3632	CVE-2004-2687	H	PCI DSS 6.2; CIS Control 7	Unauthenticated RCE — attacker executes arbitrary commands as the service user
PostgreSQL empty/default password	PostgreSQL – port 5432	pgsql-empty-password, postgres-default-logins	H	CIS Control 5 (credential mgmt); NIST PR.AC-1	Unauthorized database access; exposure of all stored data

VNC default credentials	VNC – port 5900	vnc-default-login	H	CIS Control 5; ISO 27001 A.9.4.3	Full remote desktop access to the system — complete control without exploitation
MySQL outdated version	MySQL – port 3306	mysql-info (v5.0.51a-3ubuntu5)	M	CIS Control 7 (patch management)	Legacy, unsupported DB version with multiple known vulnerability classes; potential data exposure
FTP weak/default credentials (multiple accounts)	FTP – port 21	ftp-weak-credentials	M	CIS Control 5; NIST PR.AC-1	Unauthorized file system access via trivially guessable passwords
FTP anonymous login enabled	FTP – port 21	ftp-anonymous-login	M	CIS Control 4; PCI DSS 2.1	Unauthenticated users can browse/retrieve files from the server
SMBv1 enabled	SMB – port 445	smb-v1-supported	M	CIS Control 4 (secure config); NIST PR.PT-3	Exposes host to SMBv1-based exploits (e.g., EternalBlue-class attacks)
Weak SSH key exchange/cipher algorithms	SSH – port 22	ssh-weak-algo-supported, ssh-diffie-hellman-logjam, ssh-cbc-mode-ciphers	L	CIS Control 3 (data protection); NIST PR.DS-2	Weakens confidentiality of remote admin sessions; theoretically crackable
Missing HTTP security headers	Web (HTTP) – port 80	http-missing-security-headers	L	OWASP Secure Headers; ISO 27001 A.14.1.2	Increases exposure to clickjacking, MIME-sniffing, and XSS-class attacks

EXECUTIVE SUMMARY

To: IT Management
From: GRC Audit Team
Date: October 25, 2026
Subject: High-Risk Findings on Development Server 'Metasploitable'

1. Executive Summary

A vulnerability assessment of the internal development server revealed multiple critical and high-risk security vulnerabilities that pose an immediate threat to the organization's information assets. The system is non-compliant with several key industry frameworks, including CIS Controls, NIST CSF, and PCI DSS. Six critical or high-severity remote compromise vectors were identified, alongside systemic weaknesses in credential management and the use of outdated, unsupported software across nearly every network service.

2. Key Findings & Risks

- **Critical Risk – Remote System Compromise:** The FTP service contains a known backdoor (CVE-2011-2523) that allows attackers to gain full, unauthenticated control of the system. A separate critical flaw in the web application connector (Ghostcat, CVE-2020-1938) permits remote code execution. Both violate the organization's patch management policy (CIS Control 7).
- **High Risk – Unauthenticated Database Access:** The PostgreSQL database is configured with an empty/default password, exposing all stored data to unauthorized access (CIS Control 5; NIST CSF PR.AC-1).
- **High Risk – Weak and Default Authentication:** FTP and VNC services accept multiple default or trivially guessable passwords, and FTP anonymous login is enabled, significantly increasing the risk of unauthorized access (CIS Control 5).
- **High Risk – Legacy Software and Protocols:** The server runs outdated, unsupported versions of core services (Samba, MySQL, SSH), including SMBv1, a protocol associated with major historical breaches. This reflects a lack of ongoing patch management (CIS Control 7).
- **Medium/Low Risk – Insecure Configuration:** SSH is configured with weak cryptographic algorithms, and the web server is missing standard security headers, both of which weaken the organization's overall security posture (NIST CSF PR.DS-2).

3. Recommended Actions

- **Immediate Isolation:** Remove the server from the network until the critical findings are remediated.
- **Remediate:** Apply security patches immediately for vsFTPd, Apache Tomcat, Samba, and PostgreSQL; disable or reset all default credentials.

- **Harden:** Disable unnecessary legacy services (SMBv1, rlogin, NFS, NetBIOS); enforce strong, unique passwords across all services; disable anonymous FTP access.
- **Process Review:** Reinforce secure configuration baselines for new system deployments and implement a recurring vulnerability scanning cadence to prevent recurrence.